title: “Week 3 Weekend Assignment” subtitle: “Learn it, scan it, break it, fix it”

Week 3 Weekend Assignment

Learn it, scan it, break it, fix it

Practical Cyber Security · Week 3 · 15 marks Hand in: ONE PDF, before Monday. Your instructor will tell you where to upload it.

The rules (read first)

1. **Only your assigned target.** Your instructor gives you one lab target (Metasploitable 2, DVWA or Juice Shop). Test nothing else.
2. **Snapshot first.** Before you start, take a snapshot of your lab so you can reset it.
3. **Lab only.** Everything happens inside your own lab network. Never point these tools at a real website, a classmate's laptop, your school, or anything you do not own.
4. **Reset when done.** Restore your lab from the snapshot after Part D.

The loop

> Learn the attack → scan the target → prove the flaw → fix it → prove the fix works.

Every attack you prove, you also fix. That is the job: break it so you can protect it.

Part A: Learn (3 marks)

Complete these five free lessons at **hacksplaining.com/lessons**. They run in your browser and are safe.

#	Lesson
1	SQL Injection
2	Cross-Site Scripting
3	Command Execution
4	Directory Traversal
5	Broken Access Control

For **each** lesson, hand in:

- a screenshot of the completed lesson
- three one-line answers: **the attack** (what it does), **how it works**, **the fix**

Part B: Recon and scan (4 marks)

On your assigned target:

1. **Recon.** Run `nmap -sV -sC -oA recon <ip>` and fill a service inventory table (port, service, version).
2. **Scan the web app.** Run `nikto -h http://<ip>` (add `:3000` for Juice Shop) and `nmap --script vuln <ip>`.
3. **Validate.** For every scanner finding, mark it **real**, **false positive** or **informational**, and give a reason. Scanners guess from banners. You decide what is true.
4. **Rank.** Build a ranked findings table with **at least 4 findings**. For each one use the Day 14 steps: CVE, CVSS, public exploit?, on the CISA KEV list?, context, priority, fix.

Your order must be justified. It must **not** just be sorted by CVSS score. Say why something ranks higher on *your* target.

Part C: Exploit (4 marks)

Prove **three** findings on your target.

- **At least two** must be attack types from Part A, so what you learned shows up in the lab.
- For each proof, hand in a **captioned screenshot** and **numbered steps to reproduce** (so a classmate could repeat it exactly).

”Run the exploit” is not a step. Write the command, the options you set, and what proved it worked.

Part D: Fix and retest (3 marks)

For **each** of your three proofs:

- **Fix it** where you can:
  - DVWA: raise the security level from `low` to `high`.
  - Metasploitable 2: stop or reconfigure the vulnerable service.
  - Juice Shop: it has no security switch, so write the exact fix (for example a parameterised query, output encoding, or a server-side permission check).
- **Re-run the same test.** Show it now fails (or, for Juice Shop, show the current state and your written fix).
- Hand in **before and after** screenshots.

Then re-run your Part B scan once and show the finding gone or reduced. Finally, **reset your lab from the snapshot.**

Part E: Reflection (1 mark)

3 to 4 sentences. Which attack from Part A was the **easiest** to exploit in the lab, and which was the **hardest**? Why? What would you do differently next time?

What goes in your PDF

- ☐ Part A: 5 lessons, each with a screenshot and three one-liners
- ☐ Part B: service inventory, validated scan findings, ranked findings table (4 or more)

- ☐ Part C: 3 proofs, each with a captioned screenshot and numbered steps
- ☐ Part D: before and after screenshots for each fix, scan re-run, lab reset
- ☐ Part E: reflection
- ☐ Your `nmap -oA` output files and `nikto` output
- ☐ The **exact commands** you ran

How you are marked (15 marks)

Part	What earns the marks	Marks
A	All 5 lessons, screenshot and attack / how / fix lines	3
B	Service inventory from a real scan	1
B	nikto and `nmap --script vuln` run, findings validated	1
B	Ranked table, at least 4 findings, order justified	2
C	3 proofs, at least 2 from Part A, captioned screenshot and numbered steps	4
D	Fix, retest and before/after for each; scan re-run; lab reset	3
E	Honest reflection	1

Optional stretch (no marks)

Pick **one CVE** from your scan and explain it in about half a page: what kind of flaw it is, how the public exploit works step by step, what CVSS and CISA KEV say about it, and the fix. Cite the NVD page and the exploit source (Exploit-DB ID, Metasploit module or GitHub link).

Stuck?

Ask in class or message your instructor. Come with the command you ran and the exact error. One clean, reproducible finding is worth more than five half-finished ones.